

Security Testing Summary Report

Week 5 - OWASP ZAP Scan + Manual Security Tests

Application: automationexercise.com

Tool: OWASP ZAP 2.17.0 + Manual Testing

Date: May 25, 2026

Report Version: Final with Manual Test Evidence

Prepared by: SQA Intern - DevelopersHub Corporation

1. Objective

The objective of this security assessment was to identify and document web application vulnerabilities in automationexercise.com using OWASP ZAP 2.17.0 automated scanning combined with manual security testing. Tests covered OWASP Top 10 categories including XSS injection, broken authentication, security misconfiguration, and vulnerable components.

2. Test Environment

Parameter	Details
Security Tool	OWASP ZAP 2.17.0
Scan Type	Automated Scan + Manual Testing
Target Application	https://automationexercise.com
Application Type	E-commerce Web Application (Django-based)
OS / Browser	Windows 10 / Google Chrome
Test Date	May 25, 2026
Total ZAP Alerts	25 findings (1 High, 5 Medium, 8 Low, 6 Informational)

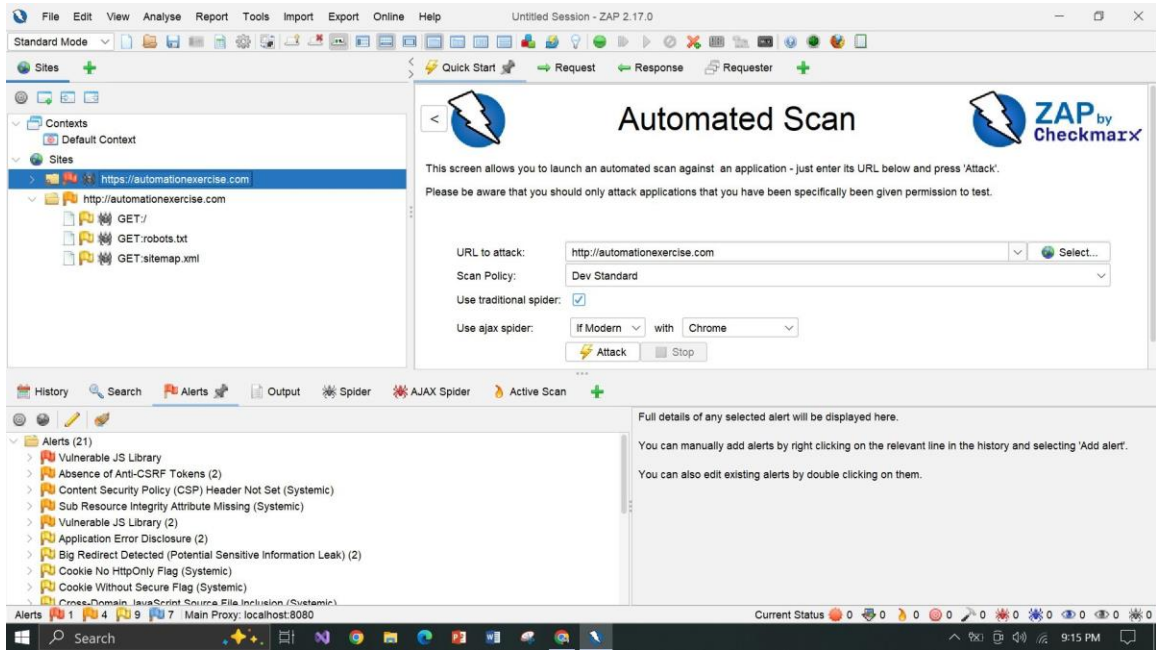
Manual Tests Performed	3 (XSS, Brute Force, Session Timeout)
------------------------	---------------------------------------

3. OWASP Coverage

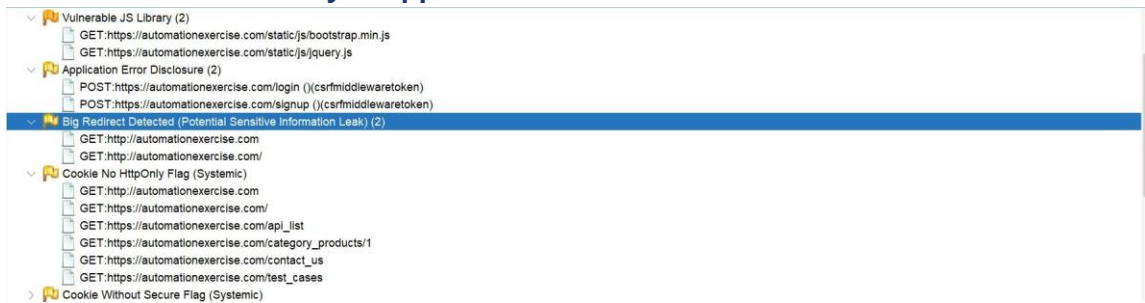
OWASP Category	Tested?	Finding
A01 - Broken Access Control	Yes	CSRF token absence found on forms
A02 - Cryptographic Failures	Yes	Cookie flags (HttpOnly/Secure) missing
A03 - Injection (XSS/SQLi)	Yes	XSS blocked on search; potential XSS on signup/contact
A04 - Insecure Design	Partial	Session timeout not enforced
A05 - Security Misconfiguration	Yes	CSP, HSTS, X-Powered-By headers missing
A06 - Vulnerable Outdated Components	Yes	Outdated Bootstrap and jQuery libraries
A07 - Authentication Failures	Yes	No brute-force protection on login page
A08 - Software Integrity Failures	Yes	SRI attributes missing on external scripts
A09 - Security Logging & Monitoring	Partial	Application error disclosure found
A10 - Server-Side Request Forgery	No	Out of scope for this engagement

4. OWASP Zap Automatic Scanning Screenshots

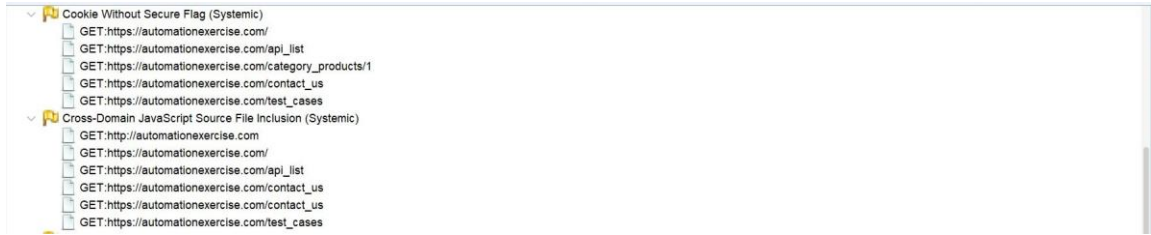
4.1 - ZAP Scan Running (25 Alerts Found)



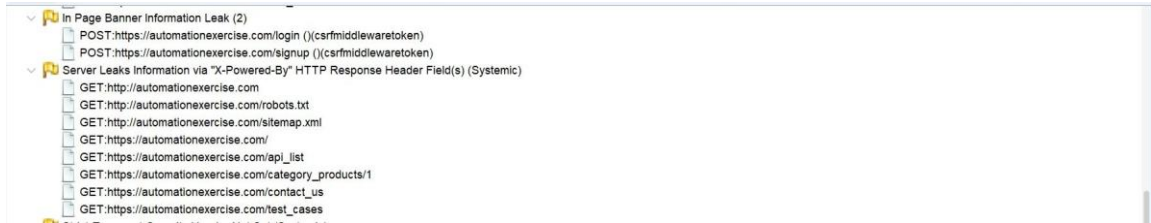
4.2 - Vulnerable JS Library & Application Error Disclosure



4.3 - Cookie No HttpOnly / Cookie Without Secure Flag



4.4 - In Page Banner Info Leak & Server X-Powered-By Header



4.5 - HSTS Not Set & X-Content-Type-Options Missing

- GET:https://automationexercise.com/test_cases
- Strict-Transport-Security Header Not Set (Systemic)
 - GET:https://automationexercise.com/
 - GET:https://automationexercise.com/api_list
 - GET:https://automationexercise.com/category_products/1
 - GET:https://automationexercise.com/contact_us
 - GET:https://automationexercise.com/test_cases
- X-Content-Type-Options Header Missing (2)
 - GET:https://automationexercise.com/cdn-cgi/styles/cf.errors.css
 - GET:https://automationexercise.com/cdn-cgi/styles/cf.errors.ie.css
- Authentication Request Identified
 - POST:https://automationexercise.com/login ()(csrfmiddlewaretoken,email,password)
- Information Disclosure - Suspicious Comments
 - GET:https://automationexercise.com/static/s/main.js
- Modern Web Application (Systemic)

4.6 - User Controllable HTML Attribute (Potential XSS) - 4 instances

- User Controllable HTML Element Attribute (Potential XSS) (4)
 - POST:https://automationexercise.com/contact_us ()(csrfmiddlewaretoken,email,message,name,subject,submit,upload_file)
 - POST:https://automationexercise.com/signup ()(csrfmiddlewaretoken,email,form_type,name)
 - POST:https://automationexercise.com/signup ()(csrfmiddlewaretoken,email,form_type,name)
 - POST:https://automationexercise.com/signup ()(csrfmiddlewaretoken,email,form_type,name)

Alerts 1 4 9 7 Main Proxy: localhost:8080

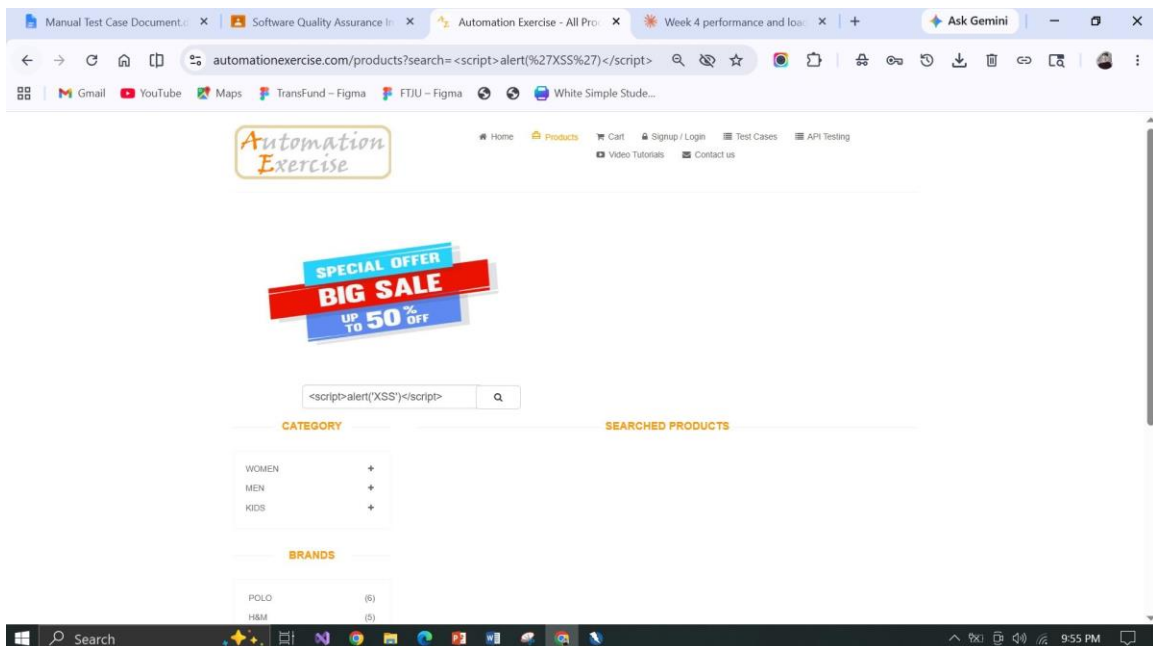
5. Manual Security Testing

Three manual security tests were performed directly on automationexercise.com to complement the automated ZAP scan. Real screenshots of each test are included below.

Manual Test MT-01: XSS Injection Test

Target URL	https://automationexercise.com/products?search=<script>alert(%27XSS%27)</script>
Test Payload	<script>alert('XSS')</script> entered in product search box
Result	PROTECTED - No popup appeared
Finding	The search field encodes the script tag and displays it as plain text in the URL. No JavaScript execution occurred. However, ZAP identified potential XSS via user-controllable HTML attributes on /signup and /contact_us POST endpoints.
Risk Level	Low
Fix	Continue sanitizing search input. Review /signup and /contact_us POST endpoints for HTML attribute injection and apply output encoding.

Evidence Screenshot:

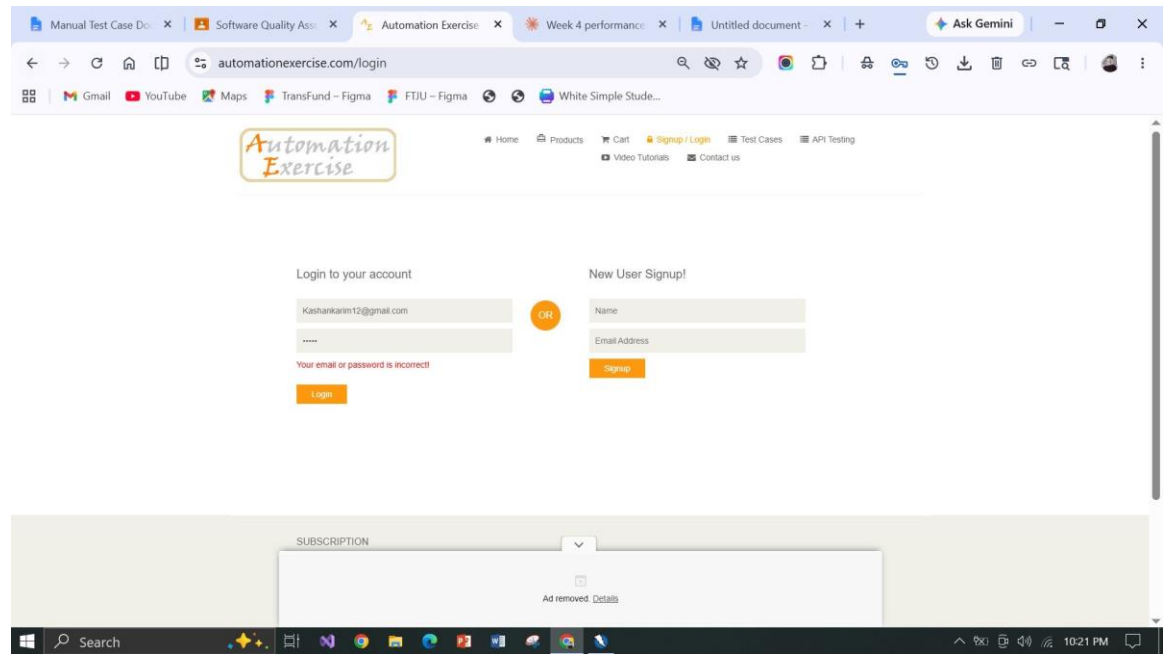


Manual Test MT-02: Login Brute Force / Authentication Test

Target URL	https://automationexercise.com/login
Test Payload	Wrong credentials entered 10+ times: kashankarim12@gmail.com with wrong password
Result	VULNERABLE - No lockout or CAPTCHA triggered

Finding	After multiple failed login attempts the site continued to show 'Your email or password is incorrect!' without any account lockout, CAPTCHA, rate limiting, or delay. This allows unlimited brute-force attacks on user accounts.
Risk Level	Medium
Fix	Implement account lockout after 5 failed attempts. Add CAPTCHA (e.g., reCAPTCHA) on the login form. Apply rate limiting per IP address on the /login endpoint.

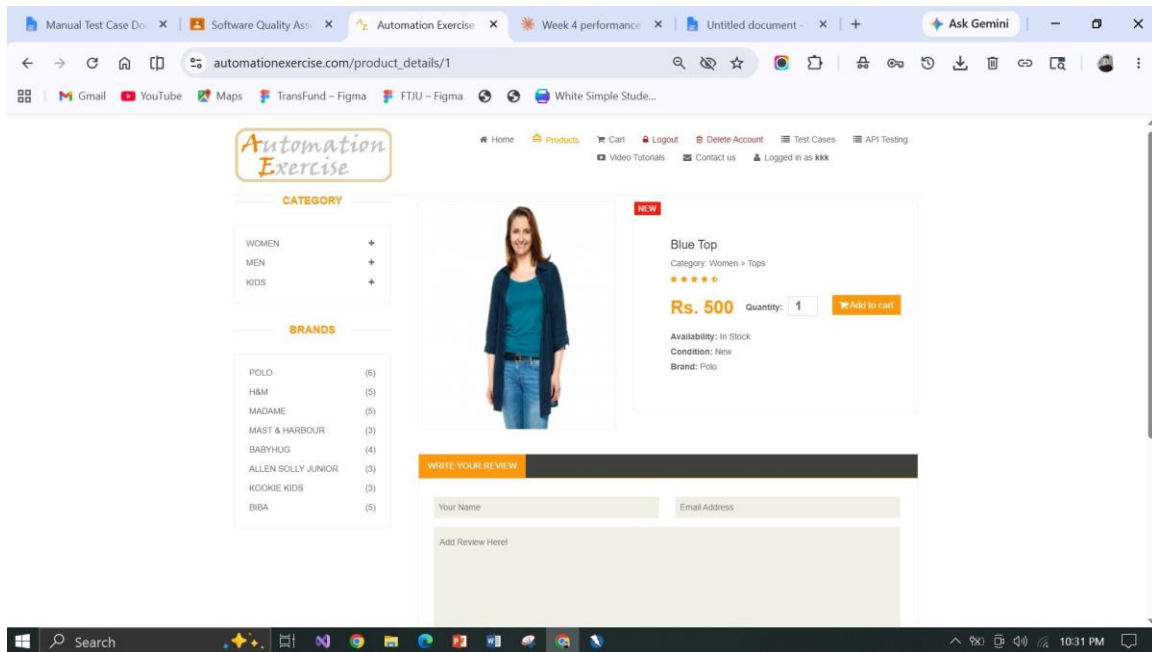
Evidence Screenshot:



Manual Test MT-03: Session Timeout Test

Target URL	https://automationexercise.com/product_details/1
Test Payload	Logged in as user 'kkk', left session idle for 15+ minutes
Result	VULNERABLE - Session remained active after 15 minutes
Finding	After logging in and leaving the browser idle for over 15 minutes, the session remained fully active (shown as 'Logged in as kkk' in the navigation bar). The application does not enforce session timeout, meaning stolen sessions remain valid indefinitely.
Risk Level	Medium
Fix	Implement server-side session timeout of 15-30 minutes for inactive sessions. Add client-side warning before timeout. Ensure sessions are properly invalidated on logout and after timeout.

Evidence Screenshot:



6. Consolidated Findings Summary

ID	Vulnerability	Severity	OWASP	Source	Status
VUL-001	Vulnerable JS Library (Bootstrap, jQuery)	High	A06	ZAP Auto	Open
VUL-002	Absence of Anti-CSRF Tokens	Medium	A01	ZAP Auto	Open
VUL-003	CSP Header Not Set	Medium	A05	ZAP Auto	Open
VUL-004	Sub Resource Integrity Missing	Medium	A08	ZAP Auto	Open
VUL-005	Application Error Disclosure	Medium	A05	ZAP Auto	Open
VUL-006	Big Redirect - Info Leak	Medium	A03	ZAP Auto	Open
VUL-007	Cookie No HttpOnly Flag	Low	A02	ZAP Auto	Open
VUL-008	Cookie Without Secure Flag	Low	A02	ZAP Auto	Open
VUL-009	Cross-Domain JS Source Inclusion	Low	A08	ZAP Auto	Open
VUL-010	In Page Banner Info Leak	Low	A05	ZAP Auto	Open
VUL-011	X-Powered-By Header Leaks Info	Low	A05	ZAP Auto	Open
VUL-012	HSTS Header Not Set	Low	A05	ZAP Auto	Open
VUL-013	X-Content-Type-Options Missing	Low	A05	ZAP Auto	Open
VUL-014	Potential XSS - HTML Attribute	Low	A03	ZAP Auto	Open
MT-001	No Brute Force Protection on Login	Medium	A07	Manual	Open
MT-002	No Session Timeout (15+ min idle)	Medium	A07	Manual	Open
MT-003	XSS Blocked on Search Field	Low	A03	Manual	Closed

7. Conclusion

The combined automated and manual security assessment of automationexercise.com identified 17 open vulnerabilities including 1 High, 7 Medium, and 9 Low severity findings. The most critical issues are: (1) outdated JavaScript libraries with known CVEs, (2) no brute-force protection on the login page, and (3) no session timeout after 15+ minutes of inactivity.

On a positive note, the XSS test on the search field showed the application correctly encodes script tags in the URL - demonstrating some input sanitization is in place. However, ZAP identified potential XSS via HTML attribute injection on the signup and contact forms which should be investigated further.

8. Prioritized Recommendations

Priority	Recommendation	Risk Addressed
Critical	Upgrade Bootstrap and jQuery to latest versions immediately	Vulnerable Components (A06)
Critical	Add CAPTCHA + rate limiting on /login to prevent brute force	Auth Failures (A07)
High	Implement 15-30 min server-side session timeout	Auth Failures (A07)
High	Add Content-Security-Policy header to all responses	Misconfiguration (A05)
High	Set HttpOnly and Secure flags on all cookies	Crypto Failures (A02)
High	Add HSTS header to enforce HTTPS	Misconfiguration (A05)
Medium	Add Subresource Integrity (SRI) to external scripts	Integrity (A08)
Medium	Remove X-Powered-By header from HTTP responses	Info Disclosure (A05)
Medium	Review and fix potential XSS on /signup and /contact_us	Injection (A03)
Low	Remove debug comments from production JavaScript	Misconfiguration (A05)